Quillmark Analytics Information Security Policy

Policy ID SEC-001, version 3.0. Effective March 1, 2026. Owner: Priya Raman, Chief Information Security Officer. Fictional company.

1. Purpose and Scope

This policy sets the minimum security requirements for everyone who uses Quillmark Analytics systems, including employees, contractors and interns. It covers company laptops, mobile devices that access company email, cloud services, source code repositories and customer data.

Version 3.0 replaces version 2.4 (June 2024). It also **supersedes Section 4.4 of the Employee Handbook** (Passwords and account security). Where the two documents disagree, this policy applies.

2. Summary of Changes in Version 3.0

- Mandatory 90-day password changes have been **removed**, in line with NIST SP 800-63B guidance. Passwords are now changed only when there is evidence or suspicion of compromise.
- Minimum password length has increased from 10 to **14 characters**.
- Phishing-resistant MFA (hardware security keys or platform passkeys) is now required for administrators and engineers with production access.
- The incident reporting window has been shortened from 24 hours to **1 hour**.
- A new Section 8 covers the use of AI tools with company data.

3. Accounts and Authentication

3.1 Passwords

- Passwords must be at least **14 characters** long. Passphrases made of several unrelated words are encouraged.
- Passwords are checked against a list of known breached passwords when they are set and are rejected if they appear on it.
- There is no scheduled password expiry. You must change your password immediately if you suspect it has been exposed, or when instructed by the Security team.
- Use the company password manager (1Password) to store work credentials. Do not store passwords in browsers, spreadsheets or notes.

3.2 Multi-factor authentication

MFA is required on every system that supports it. Approved methods, from strongest to weakest:

Method	Allowed for	Notes
Hardware security key (YubiKey 5 series)	Everyone; required for admins	Two keys issued per person
Platform passkey (Touch ID, Windows Hello)	Everyone	Must be on a managed device
Authenticator app push (Okta Verify)	Standard users	Number matching must be enabled
SMS codes	Not allowed	Removed in version 3.0

3.3 Access reviews

Managers review their team's system access every quarter. Access for people who leave the company

is removed within **4 hours** of their departure time. Shared accounts are not permitted except for documented service accounts owned by a named engineer.

4. Devices

- Company laptops must use full-disk encryption (FileVault or BitLocker), which IT enables at setup.
- Screens must lock automatically after **5 minutes** of inactivity.
- Operating system updates must be installed within **14 days** of release; critical security patches within **72 hours**.
- Personal phones may access company email and chat only after enrolling in the mobile device management (MDM) system. Personal laptops may not be used to access customer data.
- Removable USB storage is blocked on company laptops. Exceptions require Security approval and expire after 30 days.

5. Data Classification

Level	Examples	Handling rules
Public	Marketing site, published blog posts	No restrictions
Internal	Org charts, this policy, meeting notes	Share only with employees and contractors
Confidential	Source code, pricing, unreleased financials	Need-to-know access; encrypted in transit and at rest
Restricted	Customer sales data, personal data, credentials	Access logged and reviewed; never on personal devices; never in AI tools

Customer datasets are Restricted by default. Restricted data may only be stored in the approved production environment (AWS account qm-prod-01) or the analytics warehouse, and copies for testing must be anonymized first.

6. Reporting Security Incidents

Report any suspected security incident to the Security team **within 1 hour** of noticing it. Examples include a lost laptop, a suspicious login prompt, malware warnings, or accidentally sending Restricted data to the wrong person.

- Slack: #security-help (monitored around the clock)
- Email: security@quillmark.example
- Phone: extension 7000, or +1 503 555 0170 from outside

Do not try to investigate an incident yourself, and do not delete suspicious emails before Security has reviewed them. There is no penalty for reporting something that turns out to be harmless.

6.1 Incident severity levels

Severity	Definition	Response target
SEV-1	Confirmed breach of Restricted data, or a full production outage	Incident commander assigned within 15 minutes
SEV-2	Partial outage or suspected breach	Response within 1 hour
SEV-3	Limited impact, workaround available	Response within 1 business day
SEV-4	Minor issue or policy question	Response within 5 business days

7. Software and Cloud Services

Only software from the approved catalogue in Self Service may be installed on company laptops. New cloud services (SaaS) must pass a vendor security review before anyone signs up or uploads company data. The review usually takes 10 business days.

8. Use of AI Tools

- Approved AI tools are listed on the Security intranet page. As of this version, the approved list includes the company's enterprise AI assistant and the AI code assistant integrated in our code hosting platform.
- Internal and Confidential data may be used with approved tools. Restricted data may never be entered into any AI tool, approved or not.
- Locally hosted models running entirely on a company laptop (for example through Ollama) may be used with Internal data only.

9. Exceptions and Enforcement

Exceptions to this policy must be requested through the Security Exception form (SEC-EX) and approved by the CISO. Exceptions are granted for a maximum of six months. Violations may lead to disciplinary action, up to and including termination.

10. Review

This policy is reviewed every year. The next review is scheduled for March 2027.